

Beyond the CBOM: Do Today's PQC Discovery Platforms Actually Meet What Governments Are Asking For?

By Louisa Lloyd, CISSP

The post-quantum cryptography market has developed a discovery problem.

Almost every PQC platform now promises some combination of **“complete cryptographic visibility,” “continuous discovery,” “CBOM generation,” “quantum-risk identification,”** or **“crypto-agility.”** Those are valuable capabilities. But they also make it increasingly difficult for enterprises to distinguish between discovering vulnerable cryptography and discovering enough information to *actually manage a quantum-safe transition.*

That distinction matters because governments are no longer simply asking organizations to find RSA and ECC.

Across the United States, United Kingdom, Singapore and India, the direction is increasingly clear: organizations need to understand *what cryptography they have, what it protects, what depends upon it, how important those dependencies are, who controls them, when they must*

change, how they can be migrated, and how progress will be demonstrated over time.

NIST itself now defines cryptographic inventory broadly: algorithms, protocols, keys, certificates and chains, systems and applications that depend upon cryptography, and the data being protected; particularly sensitive or long-lived data exposed to harvest-now-decrypt-later risk.

The question, therefore, is no longer:

Which product can create a CBOM?

It is:

Which products discover enough technical and business context to make the CBOM useful, and how close are they to what governments are already asking organizations to do?

The regulatory baseline: what is actually being required?

It is important not to imply that these four jurisdictions have identical legal mandates. They don't.

The U.S. has federal executive/OMB requirements applying primarily to federal agencies.

The UK's NCSC has established national migration guidance and target dates.

Singapore's CSA has published a Quantum-Safe Migration Handbook and Quantum Readiness Index, with particular significance for CII owners and government.

India's National Quantum Mission has published a national migration roadmap with sector-specific milestones.

But their direction is remarkably consistent.

United States: inventory is becoming an operational system

The U.S. approach has progressed well beyond simply asking agencies for lists of vulnerable cryptography.

The June 2026 Executive Order requires federal agencies to identify PQC migration leadership and drives migration of HVAs and high-impact systems, including PQC key-establishment milestones. NIST's NCCoE program describes its first PQC workstream as “**Cryptographic Visibility and Risk Management,**” focused on building and maintaining a comprehensive cryptographic inventory that can guide migration.

The implication is significant:

inventory → risk → prioritization → migration → evidence

rather than:

scan → CBOM → done.

United Kingdom: discovery means understanding the estate

The UK makes the distinction particularly clear.

By **2028**, the NCSC expects organizations to complete discovery and assessment and develop an initial migration plan. That plan should identify high-priority migration activities, supplier and physical-infrastructure dependencies, required investment and long-lived hardware roots of trust. Organizations should also communicate migration requirements to suppliers.

By **2031**, highest-priority migration should be completed and the roadmap refined.

By **2035**, migration across systems, services and products should be substantially complete.

A list of algorithms plainly cannot answer those questions.

Singapore: discover the crown jewels, not simply the cryptography

Singapore's July 2026 Quantum-Safe Migration Handbook and Quantum Readiness Index similarly move the discussion toward organizational readiness.

CSA specifically emphasizes identifying organizational **crown jewels**, determining readiness, prioritizing actions and repeatedly reviewing the plan as both the organization's environment and external guidance evolve.

That introduces another critical distinction:

cryptographic severity is not the same as business priority.

An RSA implementation protecting a disposable development service may be technically quantum-vulnerable.

An RSA implementation protecting intellectual property that must remain confidential for twenty years represents a fundamentally different risk.

A useful inventory must know the difference.

India: perhaps the clearest articulation of the lifecycle

India's 2026 national roadmap is particularly ambitious.

It sets national objectives including quantum resilience for Critical Information Infrastructure by 2029 and enterprise-wide PQC adoption by 2033. It also emphasizes crypto-agile PKI, migration pathways, testing/certification and hybrid deployment models.

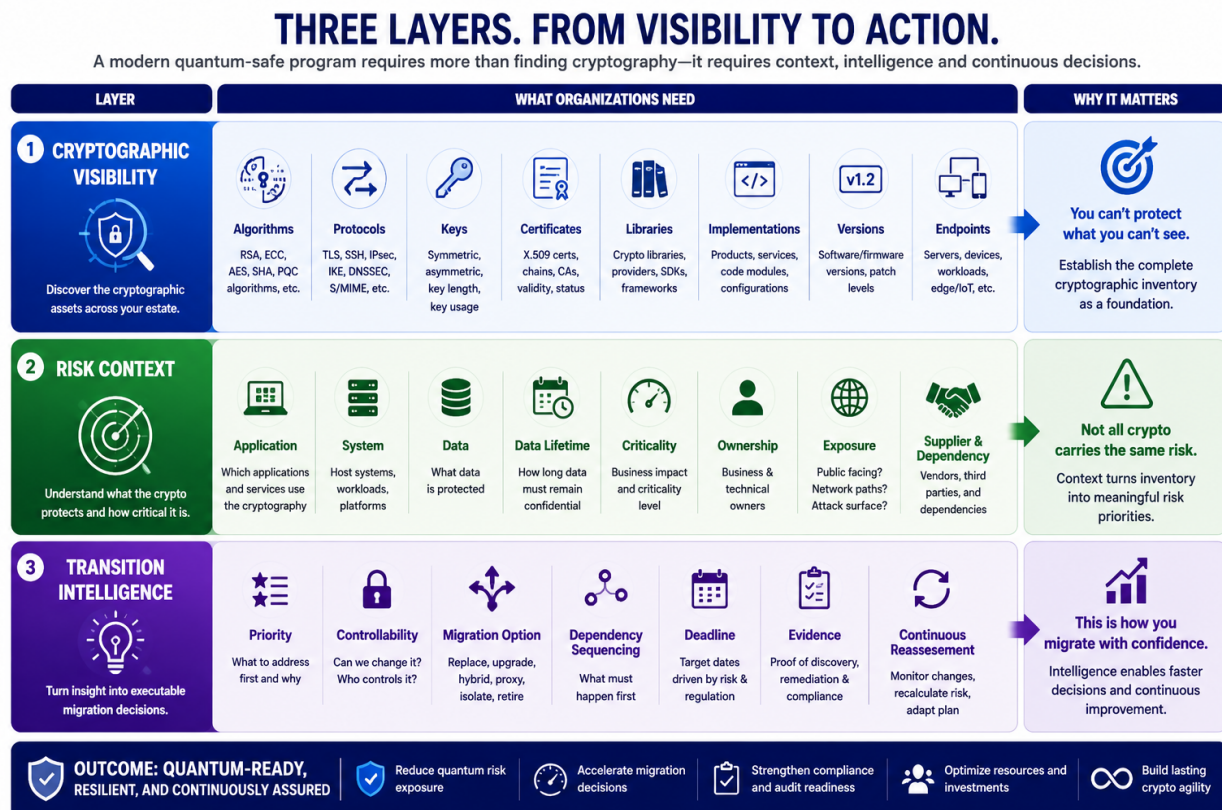
The roadmap specifically discusses CBOM transparency from cryptography providers, crypto-agility in procurement and development, risk-based adoption timelines and continuous assurance.

The message is difficult to miss:

A CBOM is an input into migration, not the end state.

The minimum viable inventory has changed

Taken together, these approaches create three increasingly distinct layers of requirements.



Most products perform strongly in the first layer.

Some are becoming very capable in the second.

Very few provide the complete third layer.

That is the market gap.

Marketing claim vs. regulatory usefulness

I reviewed the current publicly documented capabilities of several prominent platforms against this model.

This is **not a laboratory benchmark** and should not be interpreted as declaring one vendor objectively superior. It compares what vendors currently document publicly against the information organizations increasingly need to execute the regional migration expectations above.

Keyfactor AgileSec: one of the broadest crypto inventories

PQC DISCOVERY PLATFORMS: CAPABILITY COMPARISON

How Today's Leading Tools Stack Up Against What Governments Are Asking For

CAPABILITY	KEYFACTOR	IBM	ISARA	QuSecure	palto	APPVIEWX	SANDBOXAQ	HOW CLOSE ARE THEY TO WHAT GOVERNMENTS ARE REQUESTING?
	AgileSec	QS Explorer	Advance	Recon	Quantum-Safe Security (QSS)	Quantum Trust Hub (QTH)	AQVe Guard	
Algorithms/protocols	●	●	●	●	●	●	●	UNITED STATES (M-26-15 & NIST) Strong on technical inventory and reporting. Program planning, vendor coordination, resource estimates and cryptographic governance remain broader than discovery.
Keys/certificates	●	●	●	●	●	●	●	
Libraries/code	●	●	●	●	●	●	●	
Network/runtime	●	○	●	●	●	●	●	UNITED KINGDOM (NCSC) Discovery must include services, data lifetime/value, suppliers, infrastructure and dependencies. Most tools excel at crypto discovery but need external context to fully meet this bar.
Cloud/hybrid	●	○	●	●	●	●	●	
Continuous inventory	●	Scan-based	●	●	●	●	●	
Ownership	●	○	●	●	via enrichment	via enrichment	●	SINGAPORE (CSA) Focus on crown jewels, readiness, prioritization and continuous plan updates. Needs business context and governance layers beyond discovery.
Crypto dependencies	●	code dependencies	●	●	●	●	●	
Business context	●	○/●	●	●	via ecosystem	○/●	●	
Data sensitivity	●	○	●	●	●	●	●	INDIA (National Quantum Mission) Demands CBOM + risk analysis + crypto-agility + vendor roadmaps + continuous monitoring. No single tool delivers the full lifecycle today.
Data confidentiality lifetime	○/●	○	○/●	○/●	○/●	○/●	●	
HNDL prioritization	●	○	●	●	●	●	●	
Supplier readiness	●	○	●	●	●	●	●	THE GAP: WHAT AN IDEAL SOLUTION SHOULD DELIVER
Migration recommendations	●/●	code-focused	●	●	●	●	●	
Regulatory reporting	●	●	●	●	●	●	●	
Full trust dependency graph	●	○	●	●	●	●	●	Agentless-First Discovery Full Trust Dependency Graph Data Lifetime & Sensitivity Context Vendor & Migration Intelligence Risk Prioritization (HNDL & Blast Radius) Regulatory Overlays (US / UK / SG / IN) Continuous Evidence & Workflow
Business blast radius	●	○	●	●	●	●	●	
Multi-jurisdiction regulatory overlay	●	○	●	●	●	●	●	
Continuous evidence lifecycle	●	○	●	●	●	●	●	THE GAP: WHAT AN IDEAL SOLUTION SHOULD DELIVER

The important finding isn't that these products are weak. They aren't.
The finding is that the problem governments are describing is becoming larger than cryptographic discovery itself.

Keyfactor describes AgileSec as continuously discovering cryptographic assets across systems, endpoints, networks, clouds and source repositories.

More importantly, its centralized inventory can enrich findings with **usage, ownership, dependencies and risk context**, and Keyfactor claims it supports integrations with CLM, GRC, ITSM and CMDB systems. That it can use dedicated sensors or leverage existing EDR and vulnerability-management tools.

That would put AgileSec significantly beyond a basic CBOM generator.

Where its claims come close

It addresses much of the technical discovery demanded by the regional approaches and introduces business impact, dependencies, continuous monitoring and workflow integrations.

Where context is still needed

The remaining question is whether the enterprise can derive, natively or through integrations:

**data confidentiality lifetime → business service →
complete trust dependency → supplier readiness →
migration feasibility → regulatory deadline.**

Those relationships determine whether an inventory becomes a migration plan.

IBM Quantum Safe Explorer: exceptionally deep, but intentionally code-centric

IBM Quantum Safe Explorer takes a different approach.

They claim it can discover cryptographic APIs, libraries, functions and PQC algorithms across multiple programming languages; identify patterns of cryptographic use; trace parameters; identify hardcoded

cryptographic information; find vulnerabilities and identify opportunities to improve crypto-agility. It can export CBOM, CSV and JSON inventory results.

Its CBOM contains cryptographic artifacts, library/protocol dependencies and vulnerabilities and is regenerated as applications are rescanned.

That's powerful software discovery.

But software cryptography is only one layer of an enterprise quantum inventory.

IBM's claimed depth makes it a valuable component of a holistic architecture, not necessarily the entire architecture.

ISARA Advance: agentless-first is strategically important

ISARA Advance claims are notable because its current design directly addresses one of the operational problems with enterprise discovery: deploying yet another agent everywhere.

ISARA describes Advance as **agentless-first**, building real-time cryptographic inventories across cloud, on-premises and hybrid environments. It inventories algorithms, protocols, primitives, key lengths, devices and

certificate information and adds contextualized business risk and prioritized remediation recommendations.

That architecture is closer to what large organizations actually need operationally.

The remaining gap is again not primarily crypto discovery.

It is enterprise context: data lifetime, business relationships, supplier readiness, migration sequencing and regulatory evidence.

QuSecure Recon: discovery connected directly to transition

QuSecure has evolved its proposition beyond simple scanning.

QuProtect Recon claims to continuously discover cryptographic assets across hybrid environments and identifies algorithms, certificates, protocols and policy violations. QuSecure explicitly positions the broader R3 platform around **Recon** → **Resilience** → **Reporting**, connecting discovery to remediation and compliance.

Its current messaging also emphasizes live CBOMs, policy compliance and evidence trails.

That transition orientation matters.

But an important scope distinction remains: QuSecure describes its continuous CBOM in relation to cryptography deployed across its managed endpoints and its broader discovery in terms of infrastructure/network visibility.

A complete enterprise transition still requires broader business, data, supplier and governance context.

Palo Alto Quantum-Safe Security: federation rather than another agent estate

Palo Alto Networks has introduced one of the more interesting architectural approaches.

Quantum-Safe Security claims it uses existing PAN-OS and Prisma infrastructure as sensors and enriches that telemetry with third-party information including CMDB/asset-management systems, EDR, access-control systems, network-cloud sources and logs.

The result is intended to correlate cryptographic behavior with applications, devices, infrastructure, IoT and business inventories.

That aligns strongly with an important architectural principle:

Don't create another massive agent deployment merely to discover the estate. Federate the telemetry enterprises already have.

Palo Alto therefore comes relatively close to the **contextual discovery** model.

The remaining opportunity is above that layer: data longevity, supplier migration commitments, cross-domain trust relationships, regulatory normalization and end-to-end migration sequencing.

AppViewX Quantum Trust Hub: strong application and cryptographic visibility

AppViewX Quantum Trust Hub claims it provides dashboards, inventories and PQC policy management and discovers cryptographic assets across code, configuration files, applications and endpoints.

Its architecture is also nuanced: certificate discovery can be agentless through network scans and native integrations, while other discovery functions may use an agent.

That makes it considerably more than traditional certificate lifecycle management.

But again, the challenge becomes what happens **after** a cryptographic object has been discovered.

Does the organization know the data it protects? Its confidentiality horizon? Every business process dependent upon it? Supplier readiness? Replacement constraints? Regulatory deadlines?

Those are increasingly the questions that matter.

SandboxAQ AQtive Guard: moving toward cryptographic posture management

SandboxAQ AQtive Guard takes another broad approach.

Its documentation describes integrations with multiple enterprise data sources, including CrowdStrike, Palo Alto Networks and ServiceNow, to create a continuously updated inventory across cloud environments. It also provides risk analysis, contextual remediation guidance, lifecycle management and NIST-oriented reporting.

Its data model includes servers, applications and the cryptographic assets they use, while maintaining historical information useful for audit and trend analysis.

That is moving toward **cryptographic posture management rather than scanning**.

But even here, there remains room between cryptographic posture and a true **enterprise trust-dependency model**.

Open source: useful sensors, not the answer

NIST NCCoE itself lists open-source components including:

pqcscan → SSH/TLS discovery

sslscan2 → TLS cipher discovery

crt.sh → certificate discovery

CyberZero PQC Edge Scanner → public-edge PQC signals

Cisco Mercury → network visibility

CodeQL → code analysis

alongside commercial collaborators such as SandboxAQ and Keyfactor.

These tools can provide excellent observations.

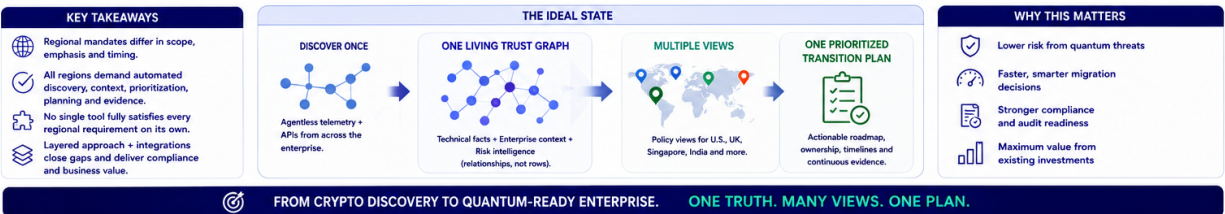
They should not be confused with an enterprise migration inventory.

PQC INVENTORY & DISCOVERY: REGIONAL REQUIREMENTS, PRIORITY & TOOL ALIGNMENT

Regional mandates vary in scope and priority. No single tool meets all requirements across all jurisdictions.

FIT LEGEND (How well tools address regional mandates)
 ★ Strong Fit ⚡ Partial Fit ⚠ Weak / Limited Fit
 — Not Applicable / Not Positioned 🚧 Emerging

WHAT MUST BE DISCOVERED	WHAT EACH REGION IS REQUIRING (With Priority)						HOW WELL TOOLS ALIGN TO REGIONAL REQUIREMENTS								
	 UNITED STATES (M-26-15 & Related)	PRIORITY	 UNITED KINGDOM (NCSC PQ Timeline)	PRIORITY	 SINGAPORE (CSA Handbook & QRI)	PRIORITY	 INDIA (National Quantum Mission Roadmap)	PRIORITY	 Keyfactor AgileSec	 IBM OS Explorer	 ISARA Advance	 QSecure Recon	 Palo Alto QSS	 AppViewX QTH	 SandboxAQ Active Guard
 Automated Crypto Discovery	Enterprise-wide automated discovery across all systems, apps, cloud, data and endpoints.	High 🔴	Complete discovery of services, apps, systems, suppliers & dependencies by 2028.	High 🔴	Identify crypto across crown jewels and critical systems first; expand to full estate.	High 🔴	Complete discovery of all crypto assets, primitives, protocols, software & hardware.	High 🔴	🟢	🟢	🟢	🟢	🟢	🟢	🟢
 Context & Ownership	Include system info, FIPS category, ownership, software/vendor, hosting.	High 🔴	Map services, data value & lifetimes, suppliers, physical infrastructure.	High 🔴	Focus on crown jewels; map owners and business impact.	High 🔴	Associate assets with owners, criticality & business sectors.	High 🔴	🟡	🔴	🟢	🔴	🟢	🟡	🟢
 Data Sensitivity & Longevity	Identify mission-sensitive & long-lived data (HNDL, risk).	High 🔴	Record data value to adversary and expected confidentiality lifetime.	High 🔴	Assess sensitivity of crown jewel data; business impact first.	High 🔴	Classify assets by type, lifetime and business criticality.	High 🔴	🔴	🔴	🔴	🔴	🔴	🔴	🔴
 Dependencies & Supply Chain	Coordinate with third parties & cloud providers; include dependencies and risks.	High 🔴	Understand supplier & infra dependencies; communicate requirements.	High 🔴	Map critical dependencies (infra, cloud, OT, suppliers).	Medium 🟡	Require vendor CBOMs, roadmaps and resilience commitments.	High 🔴	🔴	🔴	🔴	🔴	🔴	🔴	🔴
 Risk Prioritization	Risk-based prioritization using business impact, HNDL, exposure and blast radius.	High 🔴	Prioritize highest risk and long-lived legacy systems; plan by 2028.	High 🔴	Prioritize crown jewels & critical functions by readiness gaps.	High 🔴	Quantum risk analysis & prioritization by criticality & exposure.	High 🔴	🟢	🟡	🟢	🔴	🟢	🟡	🟢
 Migration Planning	Develop migration plan (120 days) with milestones, resources, crypto-agility and target dates.	High 🔴	Initial plan by 2028; high-priority migration complete by 2031; substantially complete by 2035.	High 🔴	Create quantum-safe migration plans; phased actions & timelines.	Medium 🟡	Define migration pathways; hybrid models, sector-specific timelines.	High 🔴	🟡	code-focused	🟢	🟢	🟢	🟢	🟢
 Continuous Inventory & Evidence	Continuously updated inventory (CBOM); track progress & generate evidence.	High 🔴	Inventory must remain current through migration lifecycle.	High 🔴	Regularly review & update plans; track readiness.	Medium 🟡	Continuous monitoring, validation & audit-ready evidence.	High 🔴	🔴	🔴	🔴	🟡	🔴	🟡	🟡
 Regulatory Reporting & Timelines	Submit migration plan (120 days); meet milestones; inventory methodology & reports.	High 🔴	Meet 2028, 2031, 2035 milestones with documented progress.	High 🔴	Use QRI to assess, report readiness and progress (ongoing cycles).	Medium 🟡	Meet national milestones: 2029 CI readiness; 2033 enterprise-wide PQC adoption.	High 🔴	🟢	🟡	🟢	🟢	🟢	🟢	🟢
 Crypto-Agility Assessment	Architecture & key management must support crypto-agility.	High 🔴	Crypto-agility is essential; support coexistence during migration.	High 🔴	Assess readiness for crypto-agile architecture.	Medium 🟡	Crypto-agile PQC and procurement & dev practices.	High 🔴	🟡	🟢	🟢	🟢	🟢	🟢	🟢
 Hardware Roots of Trust (Long-lived / Legacy)	Identify long-lived hardware & legacy systems; plan replacement or mitigation.	Medium 🟡	Account for hardware roots of trust and physical infrastructure.	Medium 🟡	Include OT/ICS and long-life assets in risk assessment.	Medium 🟡	Include hardware primitives and long-life systems in roadmap.	Medium 🟡	🟡	🔴	🔴	🔴	🔴	🔴	🔴



The real test: can the inventory answer a risk question?

Imagine a scanner reports:

RSA-2048 detected. Quantum vulnerable. Severity: High.

Technically correct.

Operationally, almost useless.

A risk-useful system should instead be able to say:

RSA-2048 is used by Application A to establish TLS sessions carrying research data classified Confidential.

The data must remain confidential until 2041, creating current HNDL exposure. Application A supports Critical Business Service B. Twenty-seven downstream services depend upon it. The cryptographic implementation comes from Vendor C. The customer cannot change the implementation directly. Vendor C has committed PQC support in version 9.2, scheduled for Q3 2028. Upgrade requires OS version X and changes to two dependent services. This workload therefore belongs in Migration Wave 1.

The algorithm didn't change.

The context transformed the finding into a decision.

What regulation requires versus what risk actually requires

This leads to perhaps the most useful distinction.

Regulatory minimum

Across the regional approaches, the emerging baseline is approximately:

Discover

Algorithms

Protocols

Keys

Certificates
Libraries
Systems
Applications
Infrastructure

Contextualize

Criticality
Sensitive/long-lived data
Dependencies
Suppliers
Ownership

Plan

Priority
Migration approach
Supplier dependencies
Resources
Timeline

Demonstrate

Inventory
Progress
Evidence
Governance.

But risk usefulness needs to go further.

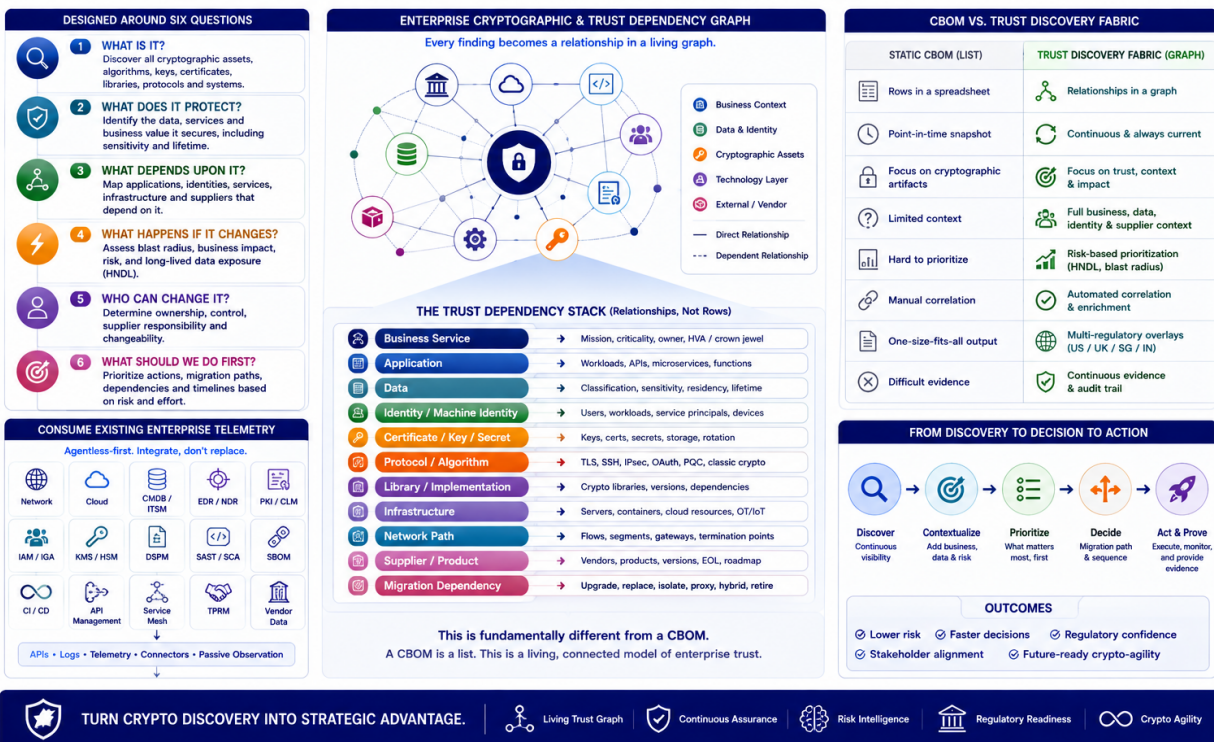
If I were designing the ideal product

I would not build another PQC scanner.

Nor would I build a product whose primary output was a CBOM.

AGENTLESS-FIRST CRYPTOGRAPHIC & TRUST DISCOVERY FABRIC

From scattered telemetry to a living trust graph — so every finding becomes a relationship, not a spreadsheet row.



The 12 capabilities I believe should become the benchmark

An enterprise-grade product should ultimately provide:

1. **Agentless-first continuous discovery**, federating existing enterprise telemetry wherever possible rather than requiring scripts or agents across every workload.
2. **Full cryptographic inventory**, covering algorithms, keys, certificates, protocols, libraries, identities, HSM/KMS, signing and hardware roots of trust.
3. **Data context**, including classification, owner, location, residency, retention and remaining confidentiality lifetime.
4. **Business context**, linking cryptography to applications, services, processes, crown jewels, HVAs and critical functions.
5. **Trust-dependency mapping**, showing what depends upon certificates, identities, CAs, keys, algorithms, APIs, vendors and trust anchors.
6. **Supplier intelligence**, including vendor control, product/version, EOL, PQC roadmap, committed dates and evidence.
7. **HNDL risk**, differentiating data that loses value next month from information requiring confidentiality for decades.
8. **Trust centrality and blast radius**, answering what breaks when a primitive, CA, library, identity system or cryptographic service changes.

9. **Migration feasibility**, classifying native PQC, hybrid, proxy/sidecar, isolation, upgrade, replacement, retirement or accepted risk.
10. **Regulatory overlays**, allowing one underlying inventory to generate U.S., UK, Singapore, India and future jurisdiction-specific views.
11. **Continuous evidence**, preserving provenance, observations, changes, approvals, remediation and historical posture rather than overwriting yesterday's CBOM.
12. **Decision-oriented output**, automatically converting discoveries into prioritized migration waves, vendor actions, blockers, dependencies, owners and evidence requirements.

That creates a very different definition of “complete inventory.”

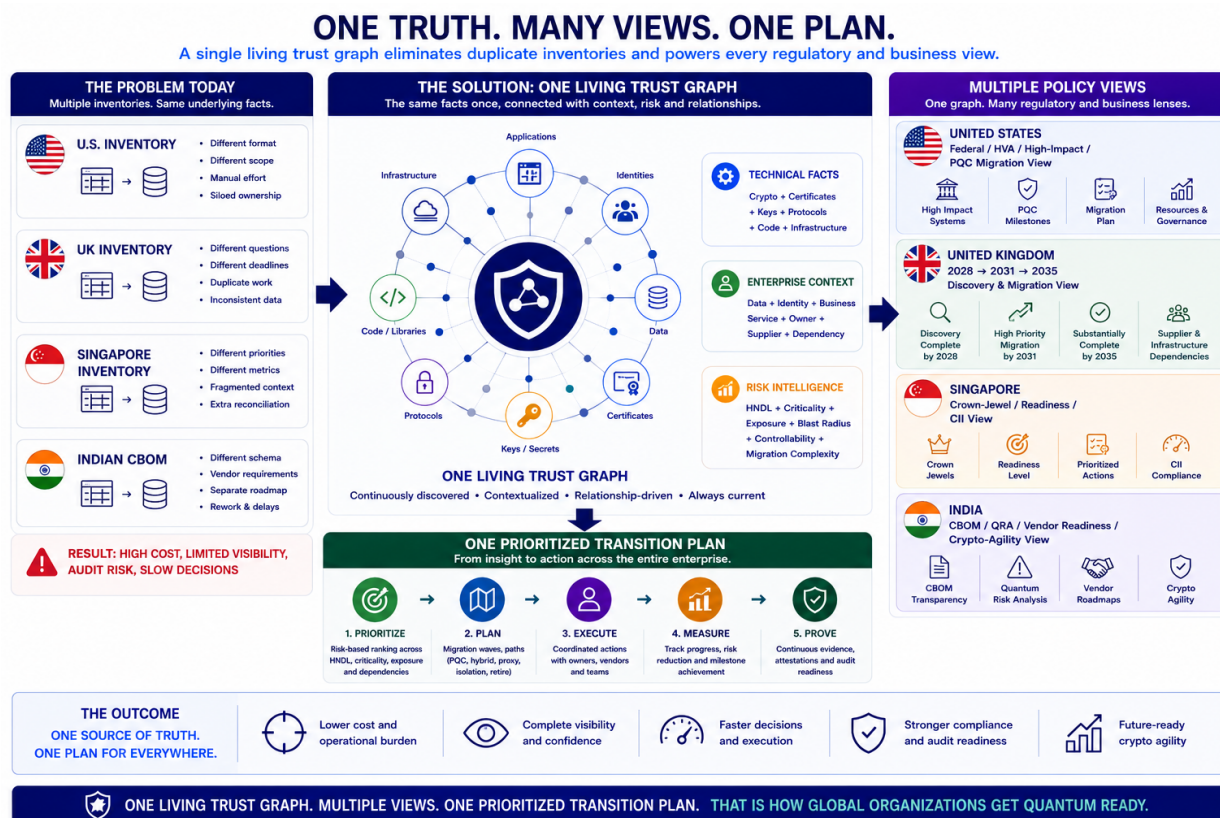
Discover once. Interpret many ways.

This may ultimately be the most important architectural principle.

An international organization should **not need a U.S. inventory, UK inventory, Singapore inventory and Indian CBOM.**

The underlying facts are largely the same.

Instead:



That is where I believe the market ultimately needs to go.

The conclusion: the CBOM isn't the destination

Today's PQC discovery products are **not failing**. Quite the opposite: Keyfactor, Palo Alto, ISARA, QuSecure, AppViewX, IBM and SandboxAQ demonstrate how quickly cryptographic discovery is maturing.

But regulatory expectations are simultaneously moving the goalposts.

Governments increasingly aren't asking:

“Do you know where your vulnerable algorithms are?”

They’re effectively asking:

“Do you understand your cryptographic dependency on them well enough to migrate your organization safely?”

Those are profoundly different questions.

A static CBOM answers:

What cryptography existed when I scanned it?

A living cryptographic inventory answers:

What cryptography exists now?

A genuinely holistic **Cryptographic & Trust Dependency Graph** should answer:

What exists, what it protects, what depends on it, why it matters, who controls it, what will break, when it needs to change, how it can change, what should change first, and whether we can prove that it did.

That is the standard against which I think the next generation of PQC discovery platforms should be measured.

If I were queen for a day - what would my ideal solution look like, and why?

Holistic Inventory and Discovery capability enterprise product, aka a living **Cryptographic & Trust Dependency Graph**.

The CBOM is one output of that graph, not the product itself.

This distinction is supported by the direction of the major national approaches.

- India's CERT-In BOM guidance describes CBOM/QBOM as structured inventories covering algorithms, keys, protocols, certificates, dependencies, usage patterns and expiration metadata.
- The UK's NCSC explicitly says discovery needs services, applications, data lifetime/value, protection in transit/at rest, infrastructure, suppliers and dependencies; not merely an asset register, and expects full discovery by 2028.
- Singapore similarly emphasizes crown jewels, readiness, prioritization and plans that are repeatedly reviewed and updated; its CII requirements already

require asset dependencies, external connections, providers, cloud services and topology.

- The U.S. federal approach requires system context such as FISMA/FIPS categorization, HVA status, algorithms, cryptographic service, key/module length, software/vendor, OS and hosting; not just vulnerable algorithm identification.

So I would give any development/product team this checklist.

Holistic Crypto & Trust Discovery Platform Requirements

Product objective

The product must answer six questions continuously:

What do we have →

what does it protect →

what depends on it →

what happens if it changes/fails →

what matters first →

what do we do about it?

If a discovery product can only answer “**where is RSA/ECC?**”, it has found a technical artifact, not quantified enterprise quantum risk.



WHAT WE MUST DISCOVER: COMPLETE ENTERPRISE CONTEXT

Crypto inventory starts with context. Discover the full ecosystem, not just cryptographic artifacts.



AGENTLESS-FIRST
Consume existing enterprise telemetry and APIs.

✓ WHAT must be discovered	🎯 WHY	☁ HOW — preferably agentless
☐  Business services	Crypto only matters in the context of the mission it supports	CMDB, service catalog, EA, ITSM APIs   
☐  Applications & microservices	Establish crypto consumers	CMDB, cloud APIs, API gateways, repositories    
☐  Infrastructure	Determine where crypto executes	Cloud control planes, virtualization, network management APIs    
☐  Network paths	Find where protection starts/terminates	Firewall/LB/SASE/API/network telemetry    
☐  APIs	APIs contain authentication, TLS, signing and machine trust	API gateways, catalogs, service mesh   
☐  Databases / data stores	Establish data-at-rest exposure	DSPM/cloud/database metadata   
☐  SaaS	Large amounts of crypto are supplier-controlled	SSPM/CASB/vendor APIs   
☐  OT / IoT	Long-lived equipment can become migration blockers	NAC, CMDB, passive network telemetry   
☐  Containers / Kubernetes	Crypto is increasingly ephemeral	K8s/cloud APIs, registries   
☐  Code / software	Find embedded crypto and libraries	SAST/SCA/SBOM/repository APIs   
☐  Third parties	Customer may not control remediation	TPRM, contracts, vendor attestations   
☐  Identity systems	Identity is fundamentally cryptographic trust	IAM/PAM/workload identity APIs   
☐  PKI / KMS / HSM	Locate roots of cryptographic trust	PKI/CLM/KMS/HSM APIs   

WHY THIS MATTERS

 See the full picture, not just the crypto.

 Identify hidden exposures and dependencies.

 Prioritize based on business impact and risk.

 Understand who owns and who can change it.

 Plan migrations with accuracy and confidence.

 Prove compliance with continuous, audit-ready data.

 **Discovery is more than finding assets. It's understanding trust.**

1. Discover the enterprise, not just cryptography

The UK guidance is especially useful here because it explicitly calls for discovery spanning software, communications hardware, mobile devices, servers, workstations, IoT/ICS, field devices and managed/service-provider dependencies.

2. Build the actual CBOM layer

For every cryptographic implementation, capture:

Identity

- ☐ Algorithm
- ☐ Algorithm family
- ☐ Symmetric/asymmetric/hash/signature/KEM/MAC
- ☐ Protocol
- ☐ Cipher suite
- ☐ Mode
- ☐ Key length
- ☐ Curve/parameters
- ☐ Crypto library/provider
- ☐ Library/version
- ☐ FIPS/module information where relevant
- ☐ Hardware implementation/HSM/KMS

Usage

- ☐ Encryption
- ☐ Authentication
- ☐ Key establishment
- ☐ Digital signature
- ☐ Code signing
- ☐ Document signing
- ☐ Machine identity

- ☐ Certificate validation
- ☐ Data integrity
- ☐ Secrets protection

Certificate/key context

- ☐ Certificate
- ☐ CA/issuer
- ☐ Root/intermediate dependency
- ☐ Expiration
- ☐ Key owner
- ☐ Rotation frequency
- ☐ Storage location
- ☐ Hardware-backed/software-backed
- ☐ Revocation mechanism

India's guidance is particularly useful here because it explicitly frames CBOM around algorithms, keys, protocols, certificates and dependencies plus metadata such as usage and expiration.

But this is only Layer 1.

3. Add data context

This is where most crypto-discovery tools become insufficient.

For every cryptographic relationship determine:

What data is being protected?

- ☐ Data classification
- ☐ Regulatory classification
- ☐ Intellectual-property classification
- ☐ Personal/financial/health/government/etc.
- ☐ Data owner
- ☐ Data location
- ☐ Data residency
- ☐ Data flow
- ☐ Data retention requirement
- ☐ Expected useful/confidential lifetime
- ☐ Exposure consequence

Then calculate:

HNDL Exposure = Data Sensitivity × Remaining Confidentiality Lifetime × Quantum Exposure

The NCSC specifically instructs organizations to record the data they hold, its expected lifetime and its value to an adversary. The U.S. federal inventory requirements similarly prioritize data expected to remain mission-sensitive into the quantum-risk period.

This transforms:

“Database X uses RSA-2048.”

into:

“Database X contains clinical IP requiring confidentiality until 2042; its replication channel relies on RSA-2048 through product Y; therefore HNDL exposure exists today.”

That is actionable intelligence.

4. Discover trust dependencies

This should be a fundamental differentiator.

Do not model:

Asset → Algorithm

Model:

**Business Service → Application → Data → Identity →
Certificate → Key → Algorithm → Library →
Infrastructure → Network → Vendor**

And relationships between them.

Capture:

- ☐ Application dependencies
- ☐ Service-to-service dependencies
- ☐ API dependencies
- ☐ Certificate chains
- ☐ PKI dependencies
- ☐ DNS/DNSSEC

- ☐ Identity providers
- ☐ Authentication dependencies
- ☐ Signing dependencies
- ☐ Code-signing chains
- ☐ CI/CD dependencies
- ☐ Secrets/KMS/HSM dependencies
- ☐ Network security dependencies
- ☐ TLS termination points
- ☐ SaaS dependencies
- ☐ Cloud dependencies
- ☐ Third-party dependencies
- ☐ Software supply-chain dependencies
- ☐ Hardware roots of trust
- ☐ Firmware/secure boot
- ☐ OT/IoT dependencies

This is why the **graph** matters.

5. Determine ownership and control

For every dependency:

- ☐ Business owner
- ☐ Technical owner
- ☐ Application owner
- ☐ Data owner
- ☐ Security owner

- ☐ Vendor owner
- ☐ Remediation owner

And critically:

Who can actually change it?

Classify:

CUSTOMER CONTROLLED

Customer can remediate.

SHARED CONTROL

Customer + vendor must coordinate.

VENDOR CONTROLLED

Customer cannot directly remediate.

UNKNOWN

Requires investigation.

That single classification changes migration planning dramatically.

6. Add supplier readiness

Every external dependency needs:

- ☐ Vendor
- ☐ Product
- ☐ Version
- ☐ Contract
- ☐ Support/EOL date
- ☐ PQC roadmap known?
- ☐ PQC support available?
- ☐ Hybrid support?
- ☐ Upgrade required?
- ☐ Replacement required?
- ☐ Vendor committed date
- ☐ Contractual commitment?
- ☐ Evidence supplied?
- ☐ Customer action required?
- ☐ Vendor dependency/blocker

The UK specifically calls for organizations to understand supply chains/service providers and communicate migration requirements to suppliers.

With these attributes an inventory and discovery solution could tell the organization:

27% of your highest-priority quantum exposure cannot currently be remediated by you because it is vendor-controlled.

That is board-level information.

7. Add migration feasibility

For every affected trust dependency determine:

- ☐ PQC-ready now
- ☐ Upgrade available
- ☐ Upgrade announced
- ☐ Hybrid possible
- ☐ Native PQC possible
- ☐ Proxy/sidecar possible
- ☐ Isolation possible
- ☐ Re-platform required
- ☐ Replace required
- ☐ Retire before quantum deadline
- ☐ Accept risk
- ☐ Unknown

This maps closely to the NCSC migration approaches: in-place migration, re-platform, retire, run to EOL or tolerate risk. NCSC also specifically recommends cryptographic agility because classical and PQC mechanisms may need to coexist during migration.

8. Prioritize by business risk, not algorithm vulnerability

This is critical.

Do **not** produce:

18,428 vulnerable RSA instances.

Produce:

143 require action now.

617 need vendor engagement.

2,900 disappear through planned refresh.

11,400 are duplicate/low-risk instances.

3,368 require further context.

Risk score should combine something like:

Quantum Risk Priority =

Crypto vulnerability

× Data longevity

× Data sensitivity

× Business criticality

× Exposure

× Trust centrality

× Dependency blast radius

× Regulatory urgency

× Migration complexity

× Vendor readiness

Then separately measure **confidence**.

A high-risk finding based on incomplete discovery should say:

Risk: Critical | Confidence: 63%

rather than manufacturing certainty.

9. Model blast radius

This is another capability I would consider essential.

Ask:

If this trust primitive changes, what breaks?

For a CA, HSM, crypto library, TLS gateway, IdP or signing service, calculate:

- ☐ Applications dependent upon it
- ☐ Business services dependent upon it
- ☐ Data flows affected
- ☐ APIs affected
- ☐ Vendors affected
- ☐ Users affected
- ☐ Regions affected
- ☐ Regulatory obligations affected

This creates **Trust Centrality**.

A certificate authority supporting 400 applications deserves different priority from an RSA certificate protecting a development server.

10. Make discovery agentless by design

An enterprise product that requires an agent or script on every workload creates another deployment program before the PQC program can even start.

The architecture should therefore be:

API + telemetry + existing-tool federation first

Connect to:

CMDB / ITSM

- Cloud APIs
- PKI/CLM
- KMS/HSM
- Network/security platforms
- EDR/NDR
- SAST/SCA
- SBOM repositories
- CI/CD
- API management
- Service mesh
- IAM/PAM

- DSPM
- CSPM/CNAPP
- SIEM/data lake
- SaaS/security APIs
- Vendor/TPRM systems

Then normalize those sources into one graph.

Passive network observation can fill protocol/TLS gaps without workload agents.

Only use targeted deep inspection when confidence is insufficient.

That creates:

Broad agentless discovery → correlation → identify blind spots → targeted validation

rather than:

Deploy 100,000 agents → run scripts → collect millions of disconnected findings.

11. Continuously reconcile rather than periodically scan

The CBOM should never really be “finished.”

It should have:

- ☐ Continuous API synchronization
- ☐ Event-driven updates
- ☐ New asset detection
- ☐ New crypto detection
- ☐ Certificate change detection
- ☐ Vendor version changes
- ☐ SBOM changes
- ☐ Application releases
- ☐ Cloud changes
- ☐ Algorithm-policy changes
- ☐ Regulatory changes
- ☐ Vendor PQC-readiness changes
- ☐ Ownership changes
- ☐ Risk-score recalculation

Singapore explicitly recommends regularly reviewing and updating quantum-safe plans as internal progress and external technology/guidance evolve.

So instead of a CBOM dated:

August 16, 2026

the product should report:

Last observed: 4 minutes ago

Coverage: 94%

Confidence: 91%

Changes since yesterday: 37
New critical exposures: 2

12. Maintain temporal history

Do not overwrite findings.

Maintain:

What existed → when → what changed → why → who approved it.

That provides:

- ☐ Historical CBOMs
- ☐ Crypto posture trends
- ☐ Algorithm migration history
- ☐ Evidence history
- ☐ Risk acceptance history
- ☐ Vendor commitment history
- ☐ Regulatory evidence
- ☐ Audit reconstruction

You effectively get a **time machine for enterprise trust**.

13. Make policy executable

Discovery should evaluate observations against policy automatically.

For example:

Policy

RSA-2048 may not protect data with confidentiality requirements extending beyond 2035.

Discovery finds:

Customer Records API → TLS → RSA-2048 → data retention until 2041.

Platform automatically generates:

Policy violation → quantum exposure → owner → remediation workflow → deadline → evidence requirement.

This is where inventory becomes orchestration.

14. Map every observation against regulatory overlays

One underlying discovery model should support multiple overlays.

USA

FISMA/FIPS categorization
HVA/high-impact status
crypto service

algorithm/key/module
vendor/software
hosting
mission-sensitive data lifetime
migration milestones.

UK

service/application
data/value/lifetime
in-transit/at-rest protection
hardware/software
supplier dependencies
physical infrastructure
migration strategy
2028/2031/2035 readiness.

Singapore

crown jewels
quantum readiness
CII/critical function
asset ownership
dependencies/connections
service providers/cloud
readiness gaps
priority actions.

India

CBOM/QBOM
algorithms
keys
certificates
protocols
dependencies
usage
expiration/lifecycle
quantum-related components.

The customer shouldn't perform four inventories.

Discover once. Apply many regulatory lenses.

15. Produce actionable outputs, not findings

A viable product should automatically produce:

Technical outputs

- ☐ Living CBOM
- ☐ QBOM where applicable
- ☐ Crypto asset inventory
- ☐ Certificate/key inventory
- ☐ Trust dependency graph
- ☐ Application dependency map

- ☐ Data/crypto map
- ☐ Supplier dependency map

Risk outputs

- ☐ HNDL exposure
- ☐ Quantum-risk score
- ☐ Trust-centrality score
- ☐ Blast radius
- ☐ Migration complexity
- ☐ Vendor dependency risk
- ☐ Regulatory exposure
- ☐ Confidence/coverage score

Program outputs

- ☐ Prioritized remediation backlog
- ☐ Application migration waves
- ☐ Vendor engagement queue
- ☐ Migration pattern recommendation
- ☐ Resource demand
- ☐ Estimated effort
- ☐ Critical path
- ☐ Blockers/dependencies

Executive outputs

- ☐ % estate discovered
- ☐ % crypto contextualized

- ☐ % quantum exposed
- ☐ critical services exposed
- ☐ long-lived data exposed
- ☐ vendor-controlled risk
- ☐ remediation progress
- ☐ regulatory readiness
- ☐ trajectory against deadlines

Evidence outputs

- ☐ Regulatory CBOM
- ☐ Evidence package
- ☐ Attestations
- ☐ Source/provenance
- ☐ Audit trail
- ☐ Historical posture
- ☐ Remediation proof

The product I would actually build

I would therefore **not market this as “CBOM Discovery.”**

I’d make the architecture:

Agentless Enterprise Discovery Fabric

↓

Crypto + Identity + Data + Application +

Infrastructure + Supplier normalization



Cryptographic & Trust Dependency Graph



Business / Data / Regulatory Context



Risk + HNDL + Trust Centrality + Blast Radius



Migration Decision Engine



Living CBOM / QBOM / Regulatory Views



Prioritized Remediation & Vendor Workflows



Evidence + Continuous Assurance

And I think the most important product requirement is this:

Never show a vulnerable algorithm without answering what it protects, what depends on it, who owns it, how important it is, whether the organization can change it, what breaks if it changes, when it must change, and what evidence proves the risk has been resolved.

That is the difference between a **crypto scanner** and a **usable enterprise trust-discovery platform**.

